

Date: 30/1/25

Lab Practical #08:

Perform network vulnerability scan using Nikto.

- Verify if Nikto is installed
- nikto -Version

```
(kali㉿kali)-[~]  
$ nikto -Version  
Nikto 2.5.0 (LW 2.5)
```

- Get the IP address of your test environment
- Ifconfig

```
(kali㉿kali)-[~]  
$ ifconfig  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
    inet 10.0.2.15 netmask 255.255.255.0 broadcast 10.0.2.255  
    inet6 fe80::8e11:a9cb:ec4e:42b7 prefixlen 64 scopeid 0x20<link>  
    ether 08:00:27:ad:25:87 txqueuelen 1000 (Ethernet)  
    RX packets 1 bytes 590 (590.0 B)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 27 bytes 3945 (3.8 KiB)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
    inet 127.0.0.1 netmask 255.0.0.0  
    inet6 ::1 prefixlen 128 scopeid 0x10<host>  
    loop txqueuelen 1000 (Local Loopback)  
    RX packets 8 bytes 480 (480.0 B)  
    RX errors 0 dropped 0 overruns 0 frame 0  
    TX packets 8 bytes 480 (480.0 B)  
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

- Run a basic vulnerability scan against the target web server
- nikto -h o Replace with the IP address of your target system.
- Screenshot: Show the scan in progress or its results.



Date: 30/1/25

1. nikto -h www.testfire.net -o 1.html -Format html

```
(student@student)-[~]
$ nikto -h www.testfire.net -o 1.html -Format html
- Nikto v2.5.0
-----
+ Target IP: 65.61.137.117 testfire.com
+ Target Hostname: www.testfire.net
+ Target Port: 80
+ Start Time: 2025-02-04 13:00:25 (GMT5.5)
-----
+ Server: Apache-Coyote/1.1
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
^C
```

www.testfire.net / 65.61.137.117 port 80	
Target IP	65.61.137.117
Target hostname	www.testfire.net
Target Port	80
HTTP Server	Apache-Coyote/1.1
Site Link (Name)	http://www.testfire.net:80/
Site Link (IP)	http://65.61.137.117:80/
URI	/
HTTP Method	GET
Description	/: The anti-clickjacking X-Frame-Options header is not present.
Test Links	http://www.testfire.net:80/ http://65.61.137.117:80/
References	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
URI	/
HTTP Method	GET
Description	/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
Test Links	http://www.testfire.net:80/ http://65.61.137.117:80/
References	https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
Host Summary	
Start Time	1970-01-01 05:30:00
End Time	2025-02-04 13:00:55
Elapsed Time	1738654255 seconds
Statistics	106 requests, errors, findings
Scan Summary	
Software Details	Nikto 2.5.0
CLI Options	-h www.testfire.net -o 1.html -Format html
Hosts Tested	0
Start Time	Tue Feb 4 13:00:24 2025
End Time	Thu Jan 1 05:30:00 1970
Elapsed Time	seconds

© 2008 Chris Sullo

- Both vulnerabilities are easily fixable by adding the appropriate security headers in the server's configuration file. Implementing these changes will enhance security by preventing clickjacking attacks and MIME-type misinterpretation.

2. nikto -h www.hackthissite.org -o 2.html -Format html

```
(student@student)-[~]
$ nikto -h www.hackthissite.org -o 2.html -Format html
- Nikto v2.5.0
-----
+ Multiple IPs found: 137.74.187.100, 137.74.187.101, 137.74.187.103, 137.74.187.102, 137.74.187.104
+ Target IP: 137.74.187.100
+ Target Hostname: www.hackthissite.org
+ Target Port: 80
+ Start Time: 2025-02-04 13:02:20 (GMT5.5)
-----
+ Server: No banner retrieved
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page / redirects to: https://www.hackthissite.org/
^C
```

www.hackthissite.org / 137.74.187.100 port 80	
Target IP	137.74.187.100
Target hostname	www.hackthissite.org
Target Port	80
HTTP Server	
Site Link (Name)	http://www.hackthissite.org:80/
Site Link (IP)	http://137.74.187.100:80/
URI	/
HTTP Method	GET
Description	/: The anti-clickjacking X-Frame-Options header is not present.
Test Links	http://www.hackthissite.org:80/ http://137.74.187.100:80/
References	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
URI	/
HTTP Method	GET
Description	/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
Test Links	http://www.hackthissite.org:80/ http://137.74.187.100:80/
References	https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
Host Summary	
Start Time	1970-01-01 05:30:00
End Time	2025-02-04 13:02:35
Elapsed Time	1738654355 seconds
Statistics	99 requests, errors, findings
Scan Summary	
Software Details	Nikto 2.5.0
CLI Options	-h www.hackthissite.org -o 2.html -Format html
Hosts Tested	0
Start Time	Tue Feb 4 13:02:19 2025
End Time	Thu Jan 1 05:30:00 1970
Elapsed Time	seconds

© 2008 Chris Sullo

- Both vulnerabilities significantly weaken the site's security but are easily fixable by adding the recommended security headers. Implementing these changes will:
- Protect users from clickjacking attacks
- Prevent browsers from misinterpreting content types
- Reduce the risk of XSS and other content-based vulnerabilities

3. nikto -h www.sneaindia.com -o 3.html -Format html

```
(student@student)-[~]
$ nikto -h www.sneaindia.com -o 3.html -Format html
- Nikto v2.5.0
-----
+ Target IP: 103.240.91.101
+ Target Hostname: www.sneaindia.com
+ Target Port: 80
+ Start Time: 2025-02-04 13:03:54 (GMT5.5)
-----
+ Server: Apache/2.4.41 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
^C
```

www.sneaindia.com / 103.240.91.101 port 80

Target IP	103.240.91.101
Target hostname	www.sneaindia.com
Target Port	80
HTTP Server	Apache/2.4.41 (Ubuntu)
Site Link (Name)	http://www.sneaindia.com:80/
Site Link (IP)	http://103.240.91.101:80/

URI	/
HTTP Method	GET
Description	/: The anti-clickjacking X-Frame-Options header is not present.
Test Links	http://www.sneaindia.com:80/ http://103.240.91.101:80/
References	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options

URI	/
HTTP Method	GET
Description	/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
Test Links	http://www.sneaindia.com:80/ http://103.240.91.101:80/
References	https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/

Host Summary

Start Time	1970-01-01 05:30:00
End Time	2025-02-04 13:04:00
Elapsed Time	1738654440 seconds
Statistics	95 requests, errors, findings

Scan Summary

Software Details	Nikto 2.5.0
CLI Options	-h www.sneaindia.com -o 3.html -Format html
Hosts Tested	0
Start Time	Tue Feb 4 13:03:53 2025
End Time	Thu Jan 1 05:30:00 1970
Elapsed Time	seconds

© 2008 Chris Sullo

- The absence of these security headers makes the site vulnerable to multiple attack vectors, but the fix is simple and can be applied at the server configuration level. Implementing these headers will:
- Prevent clickjacking attacks
Ensure browsers do not misinterpret file types
Reduce the risk of XSS and content injection attacks